Zadanie projektowe z przedmiotu "Oprogramowanie niepożądane i inspekcja kodu"

WCY23KC1S0, WCY23KC2S0, WCY23KC1S1, WCY23KC2S1, WCY23KC3S1

Wersja 2: dn. 29.05.2026 dodano punkt 2.1.f

1. Treść zadania - wymagania

Należy wykonać narzędzie rodzaju APT (*Advanced Persistent Threat*), którego zasadniczą częścią powinno być oprogramowanie „automatycznego szpiega" zdolnego do rezydowania na pewnym komputerze. Oprócz tego należy zapewnić (i zademonstrować) niezbędne wyposażenie powalające bezpiecznie odbierać informacje z APT oraz należy przedstawić instrukcje i scenariusze jego wykorzystania.

Powinien to być kod wykonywalny osadzany(**A**) trwale(**B**) na określonym(**C**) komputerze, zdolny do skrytego(**D**) śledzenia(**E**) działania operatorów(**F**) tego komputera i dostępu do niektórych zasobów informacyjnych(**G**) oraz do wyprowadzania(**H**) informacji skrycie(**I**) z zapewnieniem bezpieczeństwa(**J**) odbiorcy informacji (ukrycia jego lokalizacji i tożsamości). Dodatkowym atutem może być zapewnienie szybkiego usuwania kodu i jego śladów (**K**).

Szczegóły wymagań wypunktowano poniżej (podpunkty należy traktować jako alternatywne – im „dalszy" podpunkt zostanie zaspokojony, tym wyższa będzie ocena spełnienia wymagania; minimalne wymagania wyróżniono pogrubioną czcionką):

A. **Kod powinien być instalowany bez świadomości operatora:**
   a. Przez intruza podczas dwuminutowego dostępu fizycznego do komputera ofiary z otwartą sesją bez uprawnień administratora
   b. Nieświadomie przez operatora o uprawnieniach administratora
   c. Nieświadomie przez operatora bez uprawnień administratora
   d. Automatycznie przez atak zdalny z sieci lokalnej
   e. Automatycznie przez atak z Internetu

B. **Kod powinien przetrwać wyłączenie/restart komputera** – podjąć działanie automatycznie po wznowieniu pracy komputera.

C. **Kod powinien być przeznaczony do wykorzystania w stacjach roboczych (PC) z systemem Windows nie wcześniejszym niż Windows 10. Jako system „minimalny" można wybrać dowolny system dostępny tej klasy na komputerach laboratorium 106/65 (także w maszynach wirtualnych).**
   a. **Na „minimalnym" komputerze bez aktualizacji**
   b. Na Windows 10 zaktualizowanym
   c. Na Windows 11 (dopuszczalne opóźnienia aktualizacji)

D. **Kod powinien być możliwie trudny do wykrycia**
   a. Ignorowany przez nieuważnego/naiwnego lub zwiedzionego operatora
   b. Bez sygnalizacji po restarcie
   c. Bez żadnej sygnalizacji obecności operatorowi
   d. Dobrze (wg oceny prowadzącego) **zamaskowany w menedżerze zadań** albo
   e. Niewidoczny w menedżerze zadań

   niezależnie od widoczności dla operatora, kod może być:
   f. Wykluczany ręcznie z sygnalizacji oprogramowania antywirusowego (wymagany wiarygodny scenariusz!) przez zwiedzionego operatora

g. Wykluczany automatycznie/zdalnie z sygnalizacji oprogramowania antywirusowego, po instalacji-ataku wg punktów A.d. lub A.e.
h. Niewykrywany przez oprogramowanie antywirusowe w wersji transportowej
i. Niewykrywany przez oprogramowanie antywirusowe.

[Osiągnięcie właściwości f÷i będzie dodatkowo punktowane, jeśli zostanie zademonstrowane. Uwaga: demonstracja może być utrudniona, gdyż komputery laboratoryjne mają osłabioną ochronę antywirusową.]

E. Kod powinien mieć funkcje (<u>alternatywnie</u>, <u>do wyboru</u>):

- keyloggera:

a. Powinien rejestrować wciskane klawisze
b. Powinien rejestrować klawisze i procesy/okna przyjmujące kody z klawiatury

- <u>lub</u> infostealera:

c. **Powinien znajdować pliki wybrane** według pewnych reguł
d. **<u>lub</u>** powinien **znajdować wybrane informacje** (np. dane uwierzytelniające, hasła pamiętane w przeglądarkach internetowych itp,)

F. Kod powinien funkcjonować podczas sesji użytkownika

a. **Jednego wybranego użytkownika**
b. Każdego użytkownika komputera

G. Kod może realizować inne funkcje

a. Wyszukiwać według pewnej reguły (np. rozszerzenia nazwy) pliki
b. Wykonywać dowolną ustaloną funkcję w systemie (np. zmianę numerów kont, znakowanie pewnych plików, blokowanie systemu po wykryciu pewnego warunku)
c. Dokonywać autoaktualizacji kodu (przesyłanego z zewnątrz)

H. Kod powinien wyprowadzać informacje (co najmniej jeden ze sposobów)

a. Przez ręcznie sterowany zapis na nośniku wymiennym
b. Pocztą
c. Przez specjalną transmisję (w tym także komunikator lub inne medium społecznościowe)
d. Przez łączenie bezpośrednie z serwerem („listener") obsługującym zrzucanie danych (do „dropzone")
e. Przez automatyczny, ukryty zapis na nośnikach wymiennych

I. Wysyłanie informacji powinno być możliwie słabo rozpoznawalne

a. Dla operatora
b. Przy przeglądaniu zawartości wyprowadzanych z komputera danych (szyfrowanie/zaciemnianie) – na nośnikach wymiennych i przez sieć
c. Przy analizie ruchu sieciowego (ukrywanie komunikacji, steganografia)

J. **Sposób przekazywania informacji powinien zapewnić, że odbiorca wyprowadzanej** (por. wymaganie H) **informacji pozostanie anonimowy i nielokalizowalny** [oraz że nadawca informacji wysyłanej **<u>do</u>** ofiary pozostanie anonimowy i nielokalizowalny (o ile taka transmisja występuje)

a. Dla zwykłego operatora
b. Dla specjalisty-pracownika SOC (*Security Operation Center*)
c. Dla krajowych organów ścigania
d. Dla wszystkich (także ponadpaństwowych organizacji lub korporacji)

K. Można uwzględnić usuwanie kodu z komputera

a. Ręcznie, lokalnie wywoływane autousuwanie z zacieraniem śladów wykonywane nieświadomie przez (np. zwiedzionego) operatora

b. Automatyczne usuwanie się kodu po zadanym czasie
c. Usuwanie kodu na zdalne żądanie

2. Sposób rozliczenia

Warunki zaliczenia:

1. Należy przedstawić sprawozdanie zawierające opis uzyskanego produktu:
    a. Możliwości zastosowania (w tym reprezentatywne)
    b. Wykaz i opis części składowych – opracowanych lub adaptowanych
        i. Nazwa i informacja o funkcjach
        ii. Dokumentacja lub link do dokumentacji
        iii. Skąd pozyskano
    c. Krótki opis działania
    d. Instrukcja instalacji/użytkowania (kto jest adresatem instrukcji + czynności/scenariusze). Uwaga: nie należy przedstawiać szczegółowych dokumentacji obsługi programu/kodu, natomiast należy ująć scenariusze:
        i. Dostarczenia i osadzenia kodu na komputerze ofiary.
        ii. Przygotowania mechanizmów dostarczania informacji od ofiary do napastnika.
        iii. Obsługi odbierania informacji przez napastnika.
        iv. Ewentualnie usuwania śladów
    e. Jako odpowiednik testów akceptacji należy w oddzielnym punkcie sprawozdania zamieścić informację o powodzeniu lub porażce spełnienia każdego z wymagań. W przypadku niespełnienia wymagania może zostać zamieszczona dodatkowa informacja/uzasadnienie, jeśli była to świadoma decyzja projektowa.
    f. Sprawozdanie powinno być złożone w pliku tekstowym (format: txt, md, docx lub pdf). Uwaga: analizator nie rozróżnia kolorów(!), a **wszystkie informacje powinny być podane tekstowo** – obrazy nie będą oceniane.
2. **Na ostatnich zajęciach** zademonstrować (na maszynie **laboratoryjnej!**) działanie opracowanego rozwiązania. Rolę komputera napastnika może spełniać dowolne urządzenie (także własny komputer lub smartfon). W uzasadnionych przypadkach, na potrzeby demonstracji, osadzanie oprogramowania na komputerze „ofiary” może zostać wykonane ręcznie, po podaniu wiarygodnego scenariusza.
3. Rozwiązanie powinno co najmniej spełniać wymagania wyróżnione w „Wymaganiach” (rozdział 1 powyżej) **pogrubioną (bold)** czcionką.

Spełnienie minimalnych wymagań, przedłożenie sprawozdania i dokonanie (z powodzeniem) demonstracji zapewniają ocenę dostateczną. Wyższa ocena będzie wystawiona w przypadku przekroczenia wymagań minimalnych. Przy ocenie zostanie również uwzględniony zakres zastosowań produktu (mniejsze ograniczenia stosowalności).

W trakcie demonstracji sprawdzana będzie samodzielność/oryginalność rozwiązania. Nieoryginalność dyskwalifikuje pracę (zob. jednak punkty 4 i 5 w „Uwagi” poniżej).

3. Uwagi

1. „Komputerem” docelowym, środowiskiem testów, a także środowiskiem demonstracji mogą być maszyny wirtualne.
2. Demonstracja dopuszczalna jest wyłącznie na maszynach, które są zainstalowane w laboratorium (106/65).
   - Do niektórych z tych maszyn nie są udostępniane hasła administratora.
   - Maszyny resetowane do stanu początkowego w trakcie restartu, nie mogą być używane do demonstracji (zob. wymaganie B).
3. Można przedstawić własne oprogramowanie lub skrypty.
4. Dopuszczalne (a nawet zalecane) jest wykorzystywanie kodu i narzędzi pozyskanych lub zaadaptowanych z zasobów publicznie dostępnych.
5. Dopuszczalne (a nawet zalecane) jest wykorzystywanie narzędzi AI, ale na żadnym detektorze AI wynik badania sprawozdania nie powinien przekroczyć 40%.
6. **Do drugich zajęć projektowych sugerowane jest przedstawienie** (drogą korespondencyjną) **nieformalnego szkicu rozwiązania**. Nie jest to obowiązkowe, ani nie podlega ocenie, ale zmniejsza ryzyko porażki projektu i daje szanse uzyskania użytecznych wskazówek od prowadzącego.

4. Możliwe modyfikacje trybu zaliczania

W niezbędnych przypadkach treść niniejszego zadania zostanie odpowiednio zmodyfikowana. Informacje o modyfikacjach zostaną przekazane środkami elektronicznymi, zaś zmodyfikowane zadanie zostanie opublikowane w plikach zespołu MS Teams.

dr inż. Adam E. Patkowski, prof. WAT